

Risk Assessment Baseline Report for Pampered Pets Business

Student Name: Lauren Pechey

Student ID: 12696823

Course: Masters of Computer Science

Module: Information Security Management

Professor: Dr Sabeen Tahir

Word Count: 632 (*exluding tables, diagrams & reference list*)

Submission Date: 18 May 2026

1. Overview, Aim & Context

This report presents a structured risk assessment of Pampered Pets, a small retail business operating primarily through in-store transactions with limited digital capability. It evaluates current operational risks and those introduced through proposed digital transformation, and assesses whether digitalisation is justified based on projected revenue growth of up to 50%, supply chain cost reductions of approximately 24%, and a potential loss of up to 33% of customers without online services.

Pampered Pets operates in a traditional retail environment supported by a point-of-sale system, a legacy spreadsheet-based warehouse tool, and shared wireless connectivity used by staff and personal devices. While this reduces exposure to large-scale external cyberattacks, it increases internal vulnerability due to weak segmentation, legacy infrastructure, and unmanaged endpoints.

Risk is defined as the combination of likelihood and impact arising from a threat exploiting a vulnerability (ISO, 2022). SMEs are particularly vulnerable due to limited cybersecurity maturity and formal risk governance (NIST, 2023), requiring a structured and scalable risk management approach.

2. Methodology

The assessment adopts the NIST Risk Management Framework (RMF) as the overarching structure, providing a lifecycle approach covering identification, protection, detection, response, and recovery (Marsland, 2024; NIST, 2023). This ensures continuous risk management across the system lifecycle. The Risk Management Process (RMP) is applied to

support structured identification, analysis, evaluation, and treatment of risks (Marsland, 2024). A qualitative High/Medium/Low scale is used due to limited quantitative data and low security maturity.

For digital transformation risks, STRIDE is used to classify threats across cloud and web systems, including spoofing, tampering, and information disclosure (Nadifi et al., 2025). DREAD and Attack Trees were excluded due to subjectivity and complexity for SME-level analysis (Aoudi & Al-Aqrabi, 2026). **Table 1** summarises the selected frameworks and justification:

Component	Purpose	Justification
NIST RMF	Overall risk governance structure	Industry-standard lifecycle model suitable for SMEs undergoing digital transformation (NIST, 2018; Marsland, 2024).
RMP	Risk execution process	Ensures structured identification and mitigation of risks across the system lifecycle (Marsland, 2024).
Qualitative assessment	Risk evaluation method	Appropriate due to limited financial data and low organisational security maturity (Marsland, 2024).
STRIDE	Threat modelling for digital systems	Suitable for identifying threats in cloud and web-based architectures (Aoudi & Al-Aqrabi, 2026; Nadifi et al., 2025).
DREAD	Alternative model	Rejected due to subjective scoring limitations and inconsistent risk weighting (Aoudi & Al-Aqrabi, 2026).
Attack Trees	Alternative model	Rejected due to complexity and limited suitability for SME-scale assessments (Marsland, 2024).

Table 1: Overview of Risk Assessment Methodology

3. Risk Analysis and Evaluation

Current State (As-Is System)

A qualitative risk register aligned with the RMF and RMP was used to evaluate threats, vulnerabilities, and business impact. The analysis highlights risks driven by weak infrastructure controls, including reliance on spreadsheets, shared wireless access, and limited endpoint management (Lincke, 2024). **Table 2** presents the findings of this assessment:

Asset / Area	Threat	Vulnerability	Impact	Likelihood	Risk Level
Warehouse system	Data loss or corruption	Legacy spreadsheet-based system with no resilience controls	High operational disruption and inventory inaccuracy (Humayun et al., 2020)	High	High
Wireless network	Eavesdropping or malware injection	Shared Wi-Fi with no segmentation or enterprise controls	Compromise of internal systems and data exposure (NIST, 2023)	High	High
POS system	System failure or outage	Single point of failure with limited redundancy	Immediate halt to sales and revenue loss (ISO, 2022)	Medium	High
Staff devices	Phishing / credential compromise	Low cybersecurity awareness and unmanaged endpoints	Account takeover and data leakage (OWASP, 2024)	High	High
Business operations	Customer attrition	Lack of digital presence and online engagement channels	Reduced competitiveness and revenue decline (NIST, 2023)	Medium	High

Table 2: Current Operational Risk Assessment (As-Is Environment)

Key risks include data loss from unsupported warehouse systems, wireless interception due to insecure network design, POS disruption affecting sales continuity, phishing targeting staff devices, and customer attrition due to limited digital engagement. These represent high-likelihood, high-impact vulnerabilities (Lincke, 2024).

Mitigation measures include network segmentation, multi-factor authentication (MFA), endpoint protection, automated backups, patch management, and cybersecurity awareness training, aligned with defence-in-depth principles and ISO/IEC 27001 controls (ISO, 2022).

Digital Transformation (To-Be System)

The proposed digital transformation introduces an e-commerce platform, cloud infrastructure, CRM integration, and online marketing systems. While these enhance revenue potential and operational efficiency, they increase exposure through cloud dependency, third-party integration, and external-facing services (Seaman, 2020).

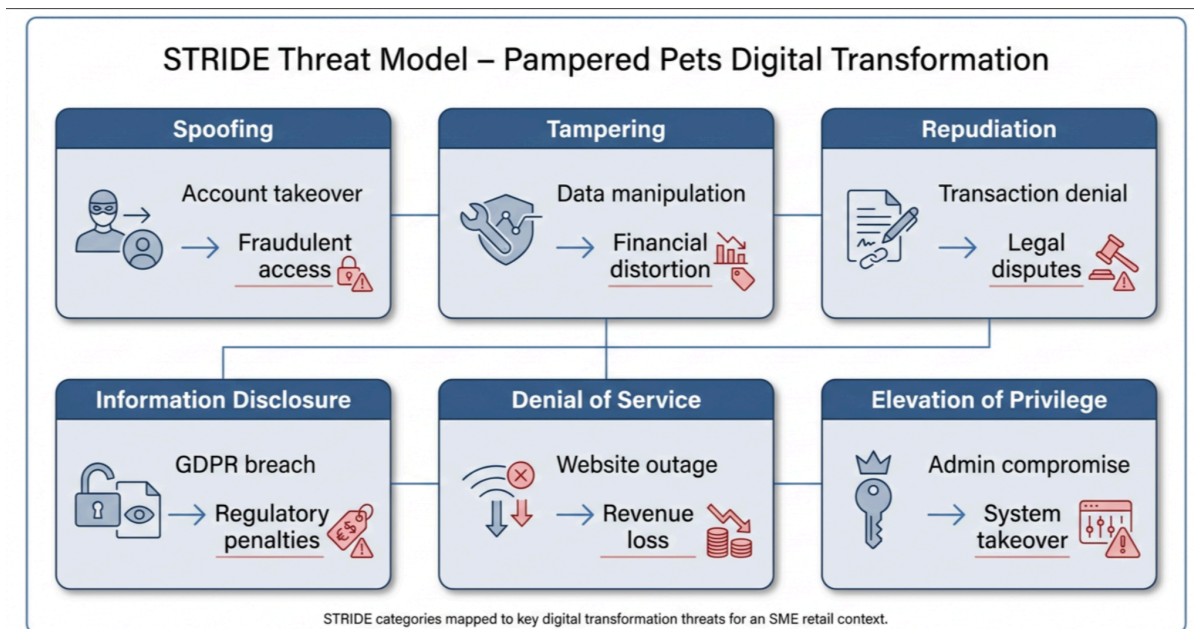


Figure 1: STRIDE Threat Modelling for Digital Transformation (Pampered Pets)

STRIDE threat modelling is used to evaluate risks in cloud and web environments (Aoudi & Al-Aqrabi, 2026). It identifies increased exposure to identity compromise, data manipulation, regulatory breaches, and service disruption, reflecting typical risks in digitally enabled SMEs (Marsland, 2024).

Strategic Risk Evaluation – Pampered Pets Digital Transformation

	Current State	Digital State	Evaluation
Cyber Exposure	Low	High (managed via controls)	Acceptable increase if mitigated with ISO/IEC 27001 controls
Business Growth	Limited	High potential	Benefits outweigh risk exposure
Operational Efficiency	Low	High	Aligns with digital transformation gains
Risk Type	Operational	Cyber + operational	Requires NIST RMF governance

Figure 2: Risk Comparison of Current vs Digital State

From a governance perspective, the current operating model reflects stagnation risk due to limited scalability and digital absence. Digital transformation introduces higher but manageable cyber risk, mitigated through structured controls and security governance (Egho-Promise et al., 2024).

4. Recommendation and Implementation Approach

The current operating model offers lower cyber exposure but limits scalability, efficiency, and customer retention. In contrast, digital transformation increases cyber risk while delivering significant gains in growth, efficiency, and resilience (Kokroko et al., 2025). Overall, the status

quo reflects stagnation risk, while digitalisation enables controlled risk expansion.

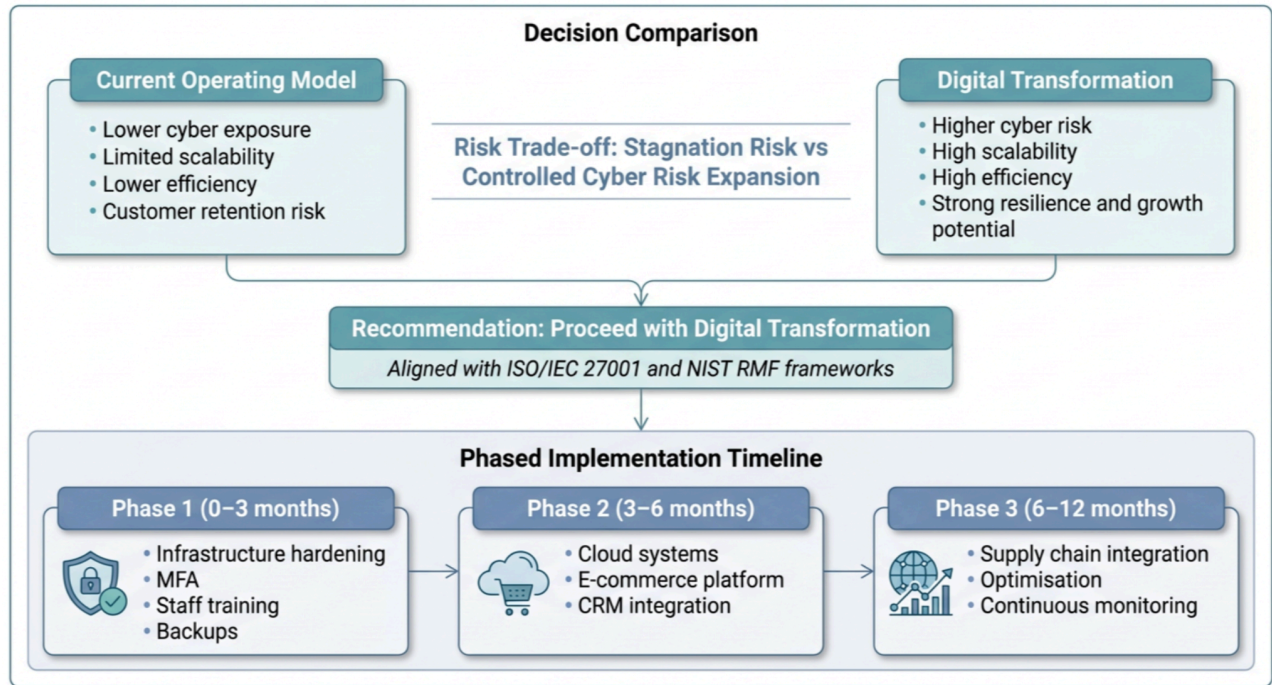


Figure 3: Phased Risk-Based Implementation Strategy for Digital Transformation

Digital transformation is recommended, provided that security controls align with ISO/IEC 27001 principles and the NIST RMF (ISO, 2022; Marsland, 2024). These controls ensure cyber and third-party risks remain within tolerance through layered security and continuous monitoring (Hussain et al., 2024).

A phased implementation approach supports controlled risk introduction and gradual capability development, while allowing security maturity to evolve alongside system deployment (Humayun et al., 2020). Ongoing alignment with RMF lifecycle stages is required for sustained risk governance (NIST, 2023).

References:

- Aoudi, S., & Al-Aqrabi, H. (2026) Integrating IoT security practices into a risk-based framework for small and medium enterprises (SMEs). *Computer Standards & Interfaces* 97: 104099. DOI: <https://doi.org/10.1016/j.csi.2025.104099>
- Egho-Promise, E., Lyada, E., Asante, G., & Anna, F. (2024) Towards improved vulnerability management in digital environments: A comprehensive framework for cyber security enhancement. *International Research Journal of Computer Science* 11(5): 441-449. DOI: <https://doi.org/10.26562/irjcs>
- Humayun, M., Niazi, M., Jhanjhi, N., Alshayeb, M., & Mahmood, S. (2020) Cyber security threats and vulnerabilities: A systematic mapping study. *Computer Engineering and Computer Science* 45(1): 3171-3189. DOI: <https://doi.org/10.1007/s13369-019-04319-2>
- Hussain, A. H., Islam, M. M., Hassan, M. M., Hasan, M. N., & Islam, S. (2024) Operationalizing The NIST AI RMF For SMEs — Top National Priority (AI Safety) And Perfect For Your Data/IT Toolkit; Produce A Lean Control Catalog, Audit Checklist, And Incident Drill For Real LLM Workflows. *Journal of International Crisis and Risk Communication Research* 7(S6): 2555. ISSN: 2576-0017.
- ISO. (2022) ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Available from: <https://www.iso.org/standard/27001> [Accessed 28 Jun 2025].
- Kokroko, B. Y., Kobi, J., & Yeboah, E. K. (2025) Risk Assessment Models Identify Potential Supply Chain Disruptions Through Scenario Analysis Monte Carlo Simulation Predictive

- Analytics. *International Journal of Innovative Science and Research Technology* 10(10): 2765. DOI: <https://doi.org/10.38124/ijisrt/25oct1432>.
- Lincke, S. (2024) *Information security planning: A practical approach*. Cham, Cham: Springer International Publishing Springer.
- Marsland, T. (2024) *Unveiling the NIST Risk Management Framework (RMF)*. Birmingham, Birmingham: Packt Publishing Ltd.
- Nadifi, Z., Ouaisa, M., Ouaisa, M., Alhyan, M., & Kartit, A. (2025) STRIDE-Based Threat Modeling and Risk Assessment Framework for IoT-enabled Smart Healthcare Systems. *International Journal of Online & Biomedical Engineering* 21(9): 63. DOI: <https://doi.org/10.3991/ijoe.v21i09.55517>
- NIST. (2023) *National Vulnerability Database*. Available at: <https://nvd.nist.gov/> [Accessed 28 June 2025].
- OWASP. (2024) *OWASP Web Security Testing Guide (WSTG)*. Available from: <https://owasp.org/www-project-web-security-testing-guide/> [Accessed 28 Jun 2025].
- Seaman, J. (2020) *PCI DSS: An Integrated Data Security Standard Guide*. Berkeley, CA: Apress.